

Cryptography

Introduction – Part 2

Clicker quiz

- What is the encryption of the plaintext 0101 0111 using the one-time pad with key 1111 1111?
 1. 0101 0111
 2. 1111 1111
 3. 1010 1000
 4. 0101 1010

Core principles of modern crypto

- Formal definitions
 - Precise, mathematical model and definition of what security means
- Assumptions
 - Clearly stated and unambiguous
- Proofs of security
 - Move away from design-break-patch

Importance of definitions

- Definitions are *essential* for the design, analysis, and sound usage of crypto

Importance of definitions -- design

- Developing a precise definition forces the designer to think about what they really want
 - What is essential and (sometimes more important) what is not
 - Often reveals subtleties of the problem

Importance of definitions -- design

If you don't understand what you want to achieve, how can you possibly know when (or if) you have achieved it?

Importance of definitions -- analysis

- Definitions enable meaningful analysis, evaluation, and comparison of schemes
 - Does a scheme satisfy the definition?
 - What definition does it satisfy?
 - Note: there may be multiple meaningful definitions!
 - One scheme may be less efficient than another, yet satisfy a stronger security definition

Importance of definitions -- usage

- Definitions allow others to understand the security guarantees provided by a scheme
- Enables schemes to be used as *components* of a larger system (modularity)
- Enables one scheme to be substituted for another if they satisfy the same definition

Assumptions

- With few exceptions, cryptography currently requires *computational assumptions*
 - At least until we prove $P \neq NP$ (and even that would not be enough)
- Principle: any such assumptions should be made explicit

Importance of clear assumptions

- Allow researchers to (attempt to) *validate* assumptions by studying them
- Allow meaningful *comparison* between schemes based on different assumptions
 - Useful to understand minimal assumptions needed
- Practical implications if assumptions are wrong
- Enable proofs of security

Proofs of security

- Provide a rigorous proof that a construction satisfies a given definition under certain specified assumptions
 - Provides an iron-clad guarantee (relative to your definition and assumptions!)
- Proofs are crucial in cryptography, where there is a malicious attacker trying to “break” the scheme

Limitations?

- Cryptography remains partly an *art* as well
- Given a proof of security based on some assumption, we still need to *instantiate* the assumption
 - Validity of various assumptions is an active area of research

Limitations?

- Proofs given an iron-clad guarantee of security
 - ...relative to the definition and the assumptions!
- Provably secure schemes can be broken!
 - If the definition does not correspond to the real-world threat model
 - I.e., if attacker can go “outside the security model”
 - This happens a lot in practice
 - If the assumption is invalid
 - If the implementation is flawed
 - This happens a lot in practice

Nevertheless...

- This does not detract from the importance of having formal definitions in place
- This does not detract from the importance of proofs of security

Defining secure encryption

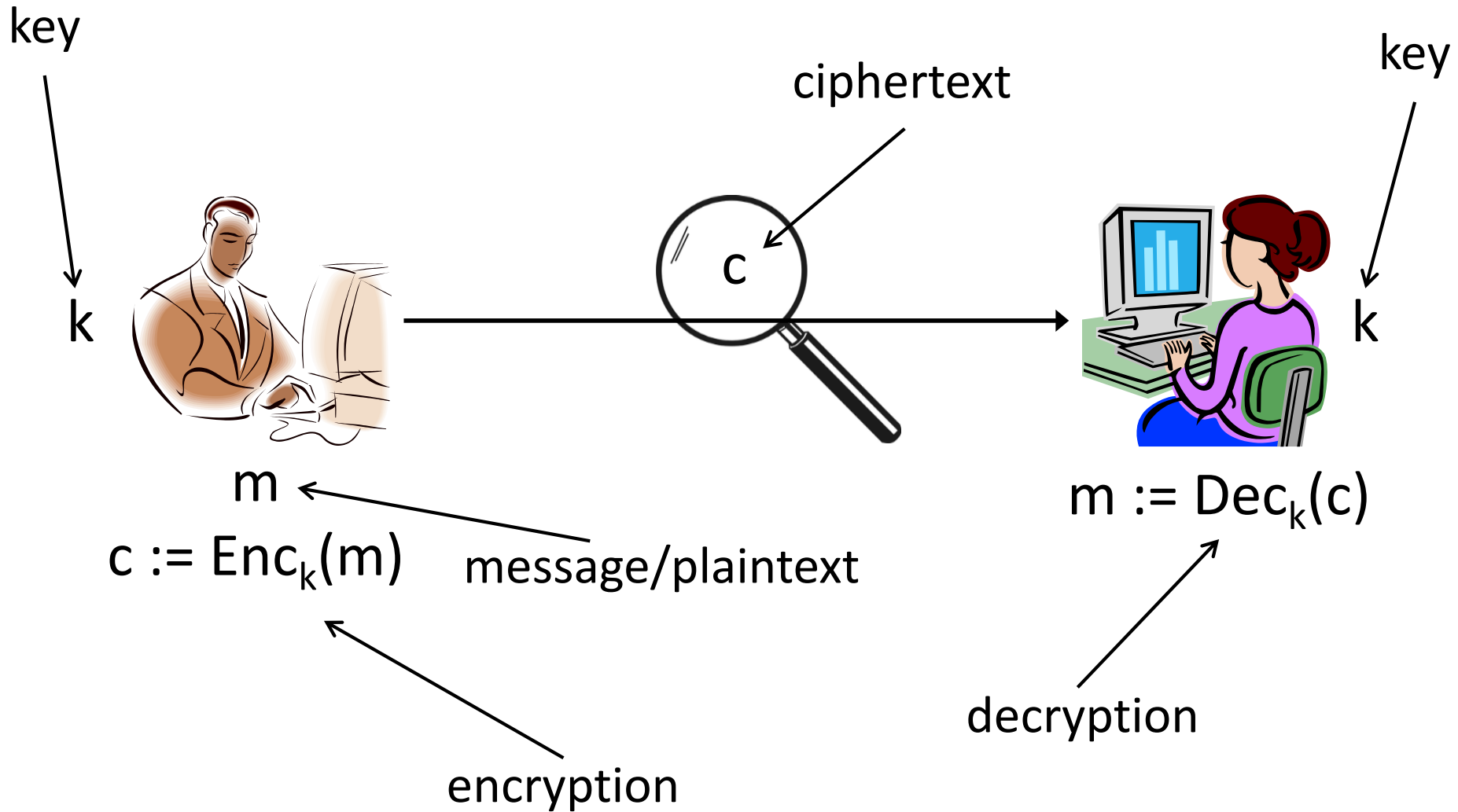
Crypto definitions (generally)

- Security guarantee/goal
 - What we want to achieve (or what we want to prevent the attacker from achieving)
- Threat model
 - What (real-world) capabilities the attacker is assumed to have

Recall

- A *private-key encryption scheme* is defined by a message space $\mathcal{M}$ and algorithms (Gen, Enc, Dec):
 - Gen (key-generation algorithm): generates k
 - Enc (encryption algorithm): takes key k and message $m \in \mathcal{M}$ as input; outputs ciphertext c
$$c \leftarrow \text{Enc}_k(m)$$
 - Dec (decryption algorithm): takes key k and ciphertext c as input; outputs m .
$$m := \text{Dec}_k(c)$$

Private-key encryption



Threat models for encryption

- Ciphertext-only attack
 - One ciphertext or many?
- Known-plaintext attack
- Chosen-plaintext attack
- Chosen-ciphertext attack

Goal of secure encryption?

- How would you define what it means for encryption scheme (Gen, Enc, Dec) over message space $\mathcal{M}$ to be secure?
 - Against a (single) ciphertext-only attack

Secure encryption?

- “Impossible for the attacker to learn the key”
 - The key is a *means to an end*, not the end itself
 - Necessary (to some extent) but not sufficient
 - Easy to design an encryption scheme that hides the key completely, but is insecure
 - Can design schemes where most of the key is leaked, but the scheme is still secure

Secure encryption?

- “Impossible for the attacker to learn the plaintext from the ciphertext”
 - What if the attacker learns 90% of the plaintext?

Secure encryption?

- “Impossible for the attacker to learn any character of the plaintext from the ciphertext”
 - What if the attacker is able to learn (other) partial information about the plaintext?
 - E.g., salary is greater than \$75K
 - What if the attacker guesses a character correctly?

The right definition

- “Regardless of any *prior* information the attacker has about the plaintext, the ciphertext should leak no *additional* information about the plaintext”
 - How to formalize?

Perfect secrecy

Probability review

- *Random variable (r.v.):* variable that takes on (discrete) values with certain probabilities
- Probability distribution for a r.v. specifies the probabilities with which the variable takes on each possible value
 - Each probability must be between 0 and 1
 - The probabilities must sum to 1

Probability review

- *Event*: a particular occurrence in some experiment
 - $\Pr[E]$: probability of event E
- Conditional probability: probability that one event occurs, *given that* some other event occurred
 - $\Pr[A \mid B] = \Pr[A \text{ and } B] / \Pr[B]$
- Two random variables X, Y are *independent* if for all x, y : $\Pr[X=x \mid Y=y] = \Pr[X=x]$

Probability review

- Law of total probability: say $E_1, \dots, E_n$ are a *partition* of all possibilities. Then for any A :

$$\Pr[A] = \sum_i \Pr[A \text{ and } E_i] = \sum_i \Pr[A \mid E_i] \cdot \Pr[E_i]$$

Notation

- $\mathcal{K}$ (key space) – set of all possible keys
- $\mathcal{C}$ (ciphertext space) – set of all possible ciphertexts

Probability distributions

- Let M be the random variable denoting the value of the message
 - M ranges over $\mathcal{M}$
 - Context dependent!
 - Reflects the likelihood of different messages being sent, given the attacker's prior knowledge
 - E.g.,
$$\Pr[M = \text{"attack today"}] = 0.7$$
$$\Pr[M = \text{"don't attack"}] = 0.3$$

Probability distributions

- Let K be a random variable denoting the key
 - K ranges over $\mathcal{K}$
- Fix some encryption scheme (Gen, Enc, Dec)
 - Gen defines a probability distribution for K :
$$\Pr[K = k] = \Pr[\text{Gen outputs key } k]$$

Probability distributions

- Random variables M and K are *independent*
 - Require that parties don't pick the key based on the message, or the message based on the key

Probability distributions

- Fix some encryption scheme (Gen, Enc, Dec), and some distribution for M
- Consider the following (randomized) experiment:
 1. Generate a key k using Gen
 2. Choose a message m , according to the given distribution
 3. Compute $c \leftarrow \text{Enc}_k(m)$
- This defines a distribution on the ciphertext!
- Let C be a random variable denoting the value of the ciphertext in this experiment

Example 1

- Consider the shift cipher
 - So for all $k \in \{0, \dots, 25\}$, $\Pr[K = k] = 1/26$
- Say $\Pr[M = 'a'] = 0.7$, $\Pr[M = 'z'] = 0.3$
- What is $\Pr[C = 'b']$?
 - Either $M = 'a'$ and $K = 1$, or $M = 'z'$ and $K = 2$
 - $\Pr[C='b'] = \Pr[M='a'] \cdot \Pr[K=1] + \Pr[M='z'] \cdot \Pr[K=2]$
 $= 0.7 \cdot (1/26) + 0.3 \cdot (1/26)$
 $= 1/26$

Example 2

- Consider the shift cipher, and the distribution on M given by

$$\Pr[M = \text{'one'}] = \frac{1}{2}, \quad \Pr[M = \text{'ten'}] = \frac{1}{2}$$

- $\Pr[C = \text{'rqh'}] = ?$
$$= \Pr[C = \text{'rqh'} \mid M = \text{'one'}] \cdot \Pr[M = \text{'one'}]$$
$$+ \Pr[C = \text{'rqh'} \mid M = \text{'ten'}] \cdot \Pr[M = \text{'ten'}]$$
$$= \frac{1}{26} \cdot \frac{1}{2} + 0 \cdot \frac{1}{2} = \frac{1}{52}$$

Some definitions

- Security Models : Security models seek to formalise the idea that a cipher is “good”
 - Perfect Secrecy : given any ciphertext, all possible plaintexts of that length are equally likely.
 - Concrete security: where we want to know how much actual work an adversary has to do.
 - Indistinguishability (standard model): specific properties of a cipher we care about. Ex: most cipher systems don't hide the length of a message, so we can't define a cipher to be secure by just requiring that an adversary not be able to distinguish ciphertexts corresponding to two messages; we have to be more explicit and require that the adversary not be able to distinguish between two messages M_1 and M_2 of the same length.
 - random oracle model : treats a function as a black box that returns a perfectly random and unpredictable output for every unique input

Perfect secrecy (informal)

- “Regardless of any *prior* information the attacker has about the plaintext, the ciphertext should leak no *additional* information about the plaintext”

Perfect secrecy (informal)

- Attacker's information about the plaintext = attacker-known *distribution* of M
- Perfect secrecy means that observing the ciphertext should not change the attacker's knowledge about the distribution of M

Perfect secrecy (formal)

- Encryption scheme (Gen, Enc, Dec) with message space $\mathcal{M}$ and ciphertext space $\mathcal{C}$ is *perfectly secret* if for every distribution over $\mathcal{M}$, every $m \in \mathcal{M}$, and every $c \in \mathcal{C}$ with $\Pr[C=c] > 0$, it holds that

$$\Pr[M = m \mid C = c] = \Pr[M = m].$$

- I.e., the distribution of M does not change conditioned on observing the ciphertext

Example 3

- Consider the shift cipher, and the distribution
 $\Pr[M = \text{'one'}] = \frac{1}{2}$, $\Pr[M = \text{'ten'}] = \frac{1}{2}$
- Take $m = \text{'ten'}$ and $c = \text{'rqh'}$
- $\Pr[M = \text{'ten'} \mid C = \text{'rqh'}] = ?$
 $= 0$
 $\neq \Pr[M = \text{'ten'}]$

Bayes's theorem

- $\Pr[A \mid B] = \Pr[B \mid A] \cdot \Pr[A] / \Pr[B]$

Example 4

- Shift cipher;
 $\Pr[M='hi'] = 0.3,$
 $\Pr[M='no'] = 0.2,$
 $\Pr[M='in'] = 0.5$
- $\Pr[M = 'hi' \mid C = 'xy'] = ?$
 $= \Pr[C = 'xy' \mid M = 'hi'] \cdot \Pr[M = 'hi'] / \Pr[C = 'xy']$

Example 4, continued

- $\Pr[C = \text{'xy'} \mid M = \text{'hi'}] = 1/26$
- $\Pr[C = \text{'xy'}]$
 - $= \Pr[C = \text{'xy'} \mid M = \text{'hi'}] \cdot 0.3 + \Pr[C = \text{'xy'} \mid M = \text{'no'}] \cdot 0.2$
 $+ \Pr[C = \text{'xy'} \mid M = \text{'in'}] \cdot 0.5$
 - $= (1/26) \cdot 0.3 + (1/26) \cdot 0.2 + 0 \cdot 0.5$
 - $= 1/52$

Example 4, continued

- $\Pr[M = \text{'hi'} \mid C = \text{'xy'}] = ?$
= $\Pr[C = \text{'xy'} \mid M = \text{'hi'}] \cdot \Pr[M = \text{'hi'}] / \Pr[C = \text{'xy'}]$
= $(1/26) \cdot 0.3 / (1/52)$
= 0.6
 $\neq \Pr[M = \text{'hi'}]$

Conclusion

- The shift cipher is not perfectly secret!
 - At least not for 2-character messages
- How to construct a perfectly secret scheme?

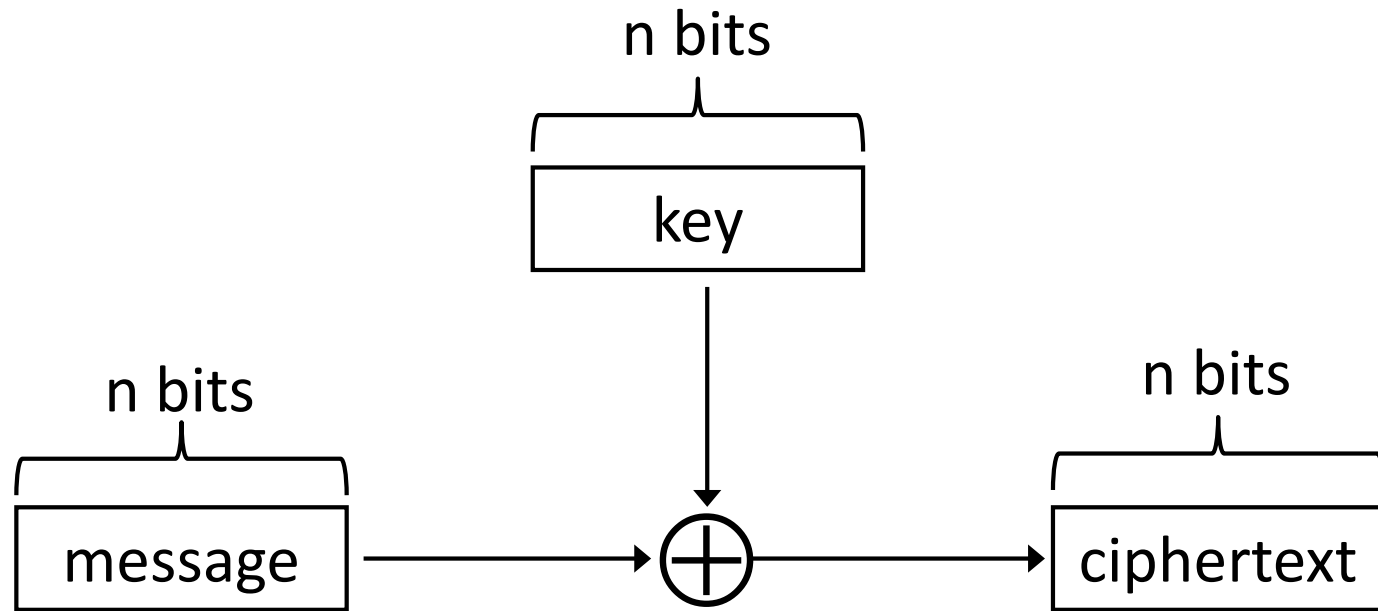
One-time pad

- Patented in 1917 by Vernam
 - Recent historical research indicates it was invented (at least) 35 years earlier
- Proven perfectly secret by Shannon (1949)

One-time pad

- Let $\mathcal{M} = \{0,1\}^n$
- Gen: choose a uniform key $k \in \{0,1\}^n$
- $\text{Enc}_k(m) = k \oplus m$
- $\text{Dec}_k(c) = k \oplus c$
- Correctness:
$$\begin{aligned}\text{Dec}_k(\text{Enc}_k(m)) &= k \oplus (k \oplus m) \\ &= (k \oplus k) \oplus m = m\end{aligned}$$

One-time pad



Perfect secrecy of one-time pad

- Note that *any* observed ciphertext can correspond to *any* message (why?)
 - (This is necessary, but not sufficient, for perfect secrecy)
- So, having observed a ciphertext, the attacker cannot conclude for certain which message was sent

Perfect secrecy of one-time pad

- Fix arbitrary distribution over $\mathcal{M} = \{0,1\}^n$, and arbitrary $m, c \in \{0,1\}^n$
- $\Pr[M = m \mid C = c] = ?$
 $= \Pr[C = c \mid M = m] \cdot \Pr[M = m] / \Pr[C = c]$
- $\Pr[C = c]$
 $= \sum_{m'} \Pr[C = c \mid M = m'] \cdot \Pr[M = m']$
 $= \sum_{m'} \Pr[K = m' \oplus c \mid M = m'] \cdot \Pr[M = m']$
 $= \sum_{m'} 2^{-n} \cdot \Pr[M = m']$
 $= 2^{-n}$

Perfect secrecy of one-time pad

- Fix arbitrary distribution over $\mathcal{M} = \{0,1\}^n$, and arbitrary $m, c \in \{0,1\}^n$
- $\Pr[M = m \mid C = c] = ?$
 - $= \Pr[C = c \mid M = m] \cdot \Pr[M = m] / \Pr[C = c]$
 - $= \Pr[K = m \oplus c \mid M = m] \cdot \Pr[M = m] / 2^{-n}$
 - $= 2^{-n} \cdot \Pr[M = m] / 2^{-n}$
 - $= \Pr[M = m]$

One Time Pad

- The one-time pad was used by several national-intelligence agencies in the mid-20th century to encrypt sensitive traffic. Perhaps most famously, the “red phone” linking the White House and the Kremlin during the Cold War was protected using one-time pad encryption, where the governments of the US and USSR would exchange extremely long keys using trusted couriers carrying briefcases of paper on which random characters were written.

One Time Pad

- One-time pad encryption is rarely used
- the key is as long as the message: limits the usefulness of the scheme for sending very long messages (as it may be difficult to securely share and store a very long key), and is problematic when the parties cannot predict in advance (an upper bound on) how long the message will be.
- The **one-time pad** is only secure if used once (with the same key) : encrypting more than one message with the same key leaks a lot of information.

Shannon Theorem

- Under certain conditions, the key-generation algorithm Gen must choose the key uniformly from the set of all possible keys (as in the one-time pad).
- For every message m and ciphertext c there is a unique key mapping m to C

Shannon Theorem

- Let $(\text{Gen}, \text{Enc}, \text{Dec})$ be an encryption scheme with message space M , for which $|M| = |K| = |C|$. The
- scheme is perfectly secret if and only if:
 - 1. Every key $k \in K$ is chosen with (equal) probability $1/|K|$ by algorithm Gen .
 - 2. For every $m \in M$ and every $c \in C$, there exists a unique key $k \in K$ such that $\text{Enc}_k(m)$ outputs c .

Shannon Theorem

- Condition 2 means that any ciphertext c could be the result of encrypting any possible plaintext m , because there is some key k mapping m to c .
- Since there is a unique such key and each key is chosen with equal probability, perfect secrecy follows as for the one-time pad.
- Perfect secrecy immediately implies that for every m and c there is at least one key mapping m to c .
- The fact that $|M| = |K| = |C|$ means, moreover, that for every m and c there is exactly one such key. Given this, each key must be chosen with equal probability or else perfect secrecy would fail to hold.

Computational Security

- Perfect secrecy is a worthwhile goal but is also unnecessarily strong.
- Perfect secrecy requires that absolutely no information about an encrypted message is leaked, even to an eavesdropper with unlimited computational power.
- For all practical purposes an encryption scheme would still be considered secure if it leaked only a tiny amount of information to eavesdroppers with bounded computational power.
- For example, a scheme that leaks information with probability at most 2^{-60} to eavesdroppers investing up to 200 years of computational effort on the fastest available supercomputer is adequate for any real-world application.
- Security definitions that take into account computational limits on the attacker, and allow for a small probability of failure, are called computational, to distinguish them from notions (like perfect secrecy) that are information-theoretic in nature.
- Computational security is now the de facto way in which security is defined for all cryptographic purposes.

Computational Security

- Computational security incorporates two relaxations relative to information theoretic notions of security :
 - 1. Security is only guaranteed against efficient adversaries that run for some feasible amount of time. This means that given enough time (or sufficient computational resources) an attacker may be able to violate security.
 - If we can make the resources required to break the scheme larger than those available to any realistic attacker, then for all practical purposes the scheme is unbreakable.
 - 2. Adversaries can potentially succeed (i.e., security can potentially fail) with some very small probability. If we can make this probability sufficiently small, we need not worry about it.

Computational Security: Concrete Approach

- The concrete approach to computational security quantifies the security of a cryptographic scheme by explicitly bounding the maximum success probability of any (randomized) adversary running for some specified amount of time or, more precisely, investing some specific amount of computational effort.
 - A scheme is (t, ϵ) -secure if any adversary running for time at most t succeeds in breaking the scheme with probability at most ϵ .

Computational Security: Asymptotic Approach

- Choose a security parameter (ex: the length of the key)
- The security parameter is assumed to be known to any adversary attacking the scheme
- The running time of the adversary is a function of the security parameter rather than as concrete numbers.
 - 1. “efficient adversaries” with randomized (i.e., probabilistic) algorithms running in time polynomial in n . This means there is some polynomial p such that the adversary runs for time at most $p(n)$ when the security parameter is n .
 - 2. The “small probabilities of success” with success probabilities smaller than any inverse polynomial in n . Such probabilities are called negligible.
- “probabilistic polynomial-time.” : PPT
- A scheme is secure if any PPT adversary succeeds in breaking the scheme with at most negligible probability.
- This notion of security is asymptotic since security depends on the behavior of the scheme for sufficiently large values of n .

General framework of any security definition

- A scheme is secure if for every probabilistic polynomial-time adversary A carrying out an attack of some formally specified type, the probability that A succeeds in the attack is negligible.
- Such a definition is asymptotic because it is possible that for small values of n an adversary can succeed with high probability.
- The term “negligible” : A scheme is secure if for every adversary A carrying out an attack of some formally specified type, and for every positive polynomial p , there exists an integer N such that when $n > N$ the probability that A succeeds in the attack is less than $1/p(n)$.
- Nothing is guaranteed for values $n \leq N$.